

Progetto corso Cybersecurity

W12D4

Analisi vulnerabilità e azioni di rimedio

Marco Jacob

Abstract

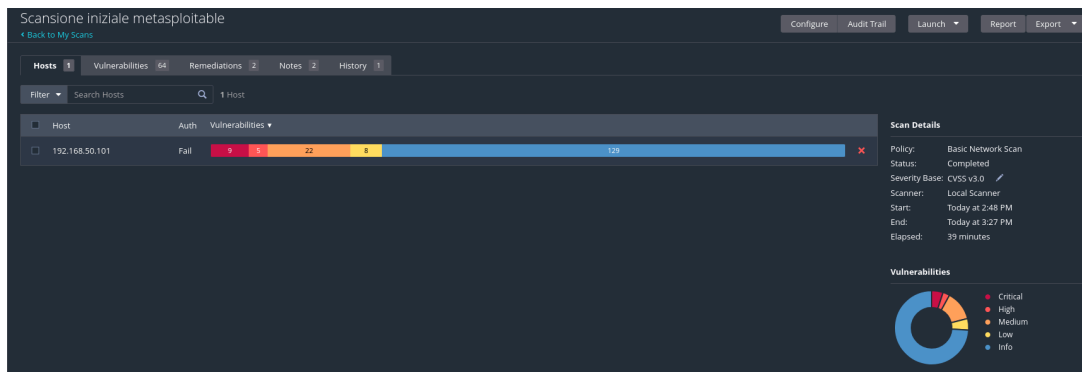
Il progetto odierno punta a esaminare le vulnerabilità del target, anche in questo caso la VM Metasploitable, con l'obiettivo di catalogarle e valutarne la superficie d'attacco e il potenziale rischio di compromissione del sistema. Per fare ciò attueremo la metodologia basata su una scansione di rete tipo Basic network scan con l'utilizzo del tool Nessus. Per questa scansione ho optato per una configurazione di rete scheda con Bridge.

- Scansione inizio

In questa fase viene documentata l'analisi iniziale delle vulnerabilità presenti sul sistema target prima delle applicazioni delle contromisure. Come richiesto dal progetto ne sono state selezionate 4 di livello **critical**:

- NFS Exported Share Information Disclosure (Porta 2049 - CVSS 10.0): Questa vulnerabilità indica che le cartelle condivise di rete sono esposte a chiunque senza alcuna restrizione o autenticazione. Un attaccante può accedere ai file interni del server da remoto;
- rlogin Service Detection (Porta 513 - CVSS 10.0): Il servizio rlogin è un protocollo obsoleto per l'accesso remoto. Le credenziali e i comandi viaggiano interamente in chiaro sulla rete, esponendo il sistema a intercettazioni;
- VNC Server Passwordless Password (Porta 5900 - CVSS 10.0): Il desktop remoto (VNC) è attivo ma non richiede nessuna password. Chiunque si colleghi può controllare l'interfaccia grafica del server senza credenziali;
- Bind Shell Backdoor Detection (Porta 1524 - CVSS 9.8): È presente una backdoor attiva sulla porta 1524. Collegandosi a

questa porta, il server cede direttamente una shell di comando con i massimi privilegi di amministrazione (root) senza chiedere login.



Sev	CVSS	VPR	EPSS	Name	Family	Count
CRITICAL	10.0			Canonical Ubuntu Linux SEOL (8.04.x)	General	1
CRITICAL	10.0	*		VNC Server 'password' Password	Gain a shell remotely	1
CRITICAL	9.8	7.9	0.9927	Apache Tomcat AJP Connector Request Injection (GHOSTcat)	Web Servers	1
CRITICAL	9.8			SSL Version 2 and 3 Protocol Detection	Service detection	2
CRITICAL	9.8			Bind Shell Backdoor Detection	Backdoors	1
CRITICAL	...	...	...	SSL (Multiple Issues)	Gain a shell remotely	3
HIGH	7.5	4.9	0.3693	Samba Badlock Vulnerability	General	1
HIGH	7.5			NFS Shares World Readable	RPC	1
MIXED	...	...	...	SSL (Multiple Issues)	General	28
MIXED	...	...	...	ISC Bind (Multiple Issues)	DNS	5
MEDIUM	6.5			TLS Version 1.0 Protocol Detection	Service detection	2
MEDIUM	5.9	6.0	0.8211	SSL DROWN Attack Vulnerability (Decrypting RSA with Obsolete and Weakened eNcryption)	Misc.	1
MEDIUM	5.9	3.0	0.1825	SSL Anonymous Cipher Suites Supported	Service detection	1
MIXED	...	...	...	SSH (Multiple Issues)	Misc.	6
MIXED	...	...	...	HTTP (Multiple Issues)	Misc.	3
MIXED	...	...	...	HTTP (Multiple Issues)	Misc.	3

- Remediation Meta

Per mettere in sicurezza il server Metasploitable e superare l'audit di sicurezza, vengono applicate le seguenti azioni correttive direttamente sul sistema operativo del target:

- Rimedio VNC: Impostazione di una credenziale d'accesso sicura tramite il terminale per bloccare l'accesso anonimo.
- Rimedio NFS: Spegnimento del servizio di condivisione file non necessario e rimozione dall'avvio automatico del sistema.
- Rimedio Backdoor (Porta 1524): Modifica manuale del file di configurazione dei servizi di rete (/etc/inetd.conf) per commentare e disattivare definitivamente la shell malevola.

```
msfadmin@metasploitable:~$ vncpasswd
Using password file /home/msfadmin/.vnc/passwd
VNC directory /home/msfadmin/.vnc does not exist, creating.
Password:
Warning: password truncated to the length of 8.
Verify:
Would you like to enter a view-only password (y/n)? y
Password:
Warning: password truncated to the length of 8.
Verify:
msfadmin@metasploitable:~$ _
```

Impostazione di una password per il servizio VNC al fine di mitigare l'accesso anonimo sulla porta 5900.

```
msfadmin@metasploitable:~$ sudo update-rc.d -f ingreslock remove
Removing any system startup links for /etc/init.d/ingreslock ...
```

Per rimuovere la backdoor attiva sulla porta 1524 è stato impartito il comando `sudo update-rc.d -f ingreslock remove`, ciò ha rimosso i link di avvio automatico del servizio disattivando in modo permanente l'esecuzione automatica della shell malevola.

```
msfadmin@metasploitable:~$ sudo /etc/init.d/nfs-kernel-server stop
* Stopping NFS kernel daemon [ OK ]
* Unexporting directories for NFS kernel daemon... [ OK ]
msfadmin@metasploitable:~$
```

A causa della configurazione che espose l'intera directory di sistema senza autenticazione si è proceduto all'arresto manuale del demone tramite il comando `sudo /etc/init.d/nfs-kernel-server stop`. L'output ne conferma il corretto smontaggio e lo spegnimento.

- Scansione finale

A seguito dell'applicazione sistematica delle contromisure di sicurezza descritte nel paragrafo precedente, è stata eseguita una seconda scansione (Basic Network Scan) per verificare la reale efficacia degli interventi. Il controllo è stato lanciato mantenendo invariati i parametri di rete e il perimetro di analisi sul target Metasploitable.

La scansione di verifica ha l'obiettivo di validare la corretta implementazione delle regole di firewalling e la conseguente riduzione della superficie d'attacco dell'host.

Ecco riportati i risultati analitici restituiti dalla piattaforma Nessus a seguito delle attività di bonifica:

Verifica finale / 192.168.50.101

ConfigureAudit TrailLaunchReportExport

Vulnerabilities62

FilterSearch Vulnerabilities62 Vulnerabilities

Sev	CVSS	VPR	EPSS	Name	Family	Count		
☐	CRITICAL	10.0		Canonical Ubuntu Linux SEOL (8.04.x)	General	1		
☐	CRITICAL	9.8	7.9	0.9927	Apache Tomcat AJP Connector Request Injection (Ghostcat)	Web Servers	1	
☐	CRITICAL	9.8			SSL Version 2 and 3 Protocol Detection	Service detection	2	
☐	CRITICAL	...	...	...	SSL (Multiple Issues)	Gain a shell remotely	3	
☐	HIGH	7.5	4.9	0.3693	Samba Badlock Vulnerability	General	1	
☐	HIGH	7.5			NFS Shares World Readable	RPC	1	
☐	MIXED	...	...	...	SSL (Multiple Issues)	General	28	
☐	MIXED	...	...	...	ISC Bind (Multiple Issues)	DNS	5	
☐	MEDIUM	6.5			TLS Version 1.0 Protocol Detection	Service detection	2	
☐	MEDIUM	5.9	6.0	0.8211	SSL DROWN Attack Vulnerability (Decrypting RSA with Obsolete and Weakened eEncryption)	Misc.	1	
☐	MEDIUM	5.9	3.0	0.1825	SSL Anonymous Cipher Suites Supported	Service detection	1	
☐	MIXED	...	...	...	SSH (Multiple Issues)	Misc.	6	

Host Details

IP:192.168.50.101
MAC:08:00:27:41:D9:A3
OS:Linux Kernel 2.6 on Ubuntu 8.04 (natty)
Start:Today at 1:50 PM
End:Today at 2:42 PM
Elapsed:an hour
KB:Download
Auth:Fail

Vulnerabilities

Critical

High

Medium

Low

Info